

TS ACADEMY — CYBERSECURITY CAPSTONE PROJECT

**PROJECT TITLE:- FROM VULNERABILITY TO COMPLIANCE:
SECURING LEGACY SYSTEMS AT APEX HEALTHCARE SOLUTIONS**

SECURITY ASSESSMENT REPORT

— BY GROUP 35

DATE: JULY 2026

TEAM MEMBERS

01	PRECIOUS REGINA MUSEI
02	ADEWOLE NOAH GBADEBO
03	DELE BLISS PAAGO
04	BAKARE OLUFEMI DANIEL
05	ANEKE CHIMEZIE CHUKWUDUBEM
06	BABALOLA IFEOLUWA ELIZABETH
07	MOHAMMED PEREIRA IBRAHIM OLAJIRE
08	FAVOUR C. OKOLIE
09	ALECHENU JUDITH OBAIYA

TABLE OF CONTENTS

TITLE PAGE	1
EXECUTIVE SUMMARY	2
VULNERABILITY FINDINGS	4
RISK ASSESSMENT	7
RECOMMENDED CONTROLS	10
RECOMMENDED POLICIES	13
CONCLUSION	18

EXECUTIVE SUMMARY

A security Assessment performed across Kioptrix and Metasploitable 2 on the legacy system used by Apex Healthcare Solutions discovered six (6) significant security vulnerabilities in total, which are Samba Trans2open Buffer Overflow, Apache mod_ssl Remote Buffer Overflow, OpenSSH Authentication Overflow, OpenSSH 4.7p1, Apache HTTP Server 2.2.8, and VSFTPD 2.3.4 Backdoor Vulnerability. These vulnerabilities expose the organization to severe cybersecurity risk, such as disclosure of sensitive healthcare information, unauthorized administrative access, privilege escalation, service interruption, remote code execution, and lateral movement within the organization's network.

During the assessment, Samba Trans2open Buffer Overflow was confirmed as the most critical from all the six identified vulnerabilities, providing malicious actors complete administrative control, thereby allowing attackers to execute arbitrary commands and code on the affected systems. Such access enables cyber attackers to modify or ruin essential system files, deactivate security mechanisms, install malicious software, acquire important patient records, and move laterally to other network systems within Apex Healthcare Solution. If not remediated, this security flaw poses a major risk to the core security objectives of the organization's information systems.

To address these findings, Apex Healthcare Solution is required to immediately integrate technical security measures such as frequent security assessments, Multi-Factor Authentication (MFA), timely software updates, Role-Based Access Control (RBAC), secure system configuration, network segmentation, and continuous security monitoring.

In addition, To enforce consistent security governance and mitigate future cybersecurity threats, it is advised that Apex Healthcare Solutions implements key GRC policies specifically **Password Policy** to require strong passwords and minimize unapproved entry; **Vulnerability Management Policy** to create a structured process for detecting and fixing security weaknesses before they can be exploited; **Access Control Policy** to enable only authorized users gain access to important systems and data; and **Patch Management Policy** to keep software updated and decrease security threats from legacy systems.

Overall, the assessment indicates that Apex Healthcare Solutions' present security state calls for enhancement to successfully safeguard against unfolding cyber attacks. The organization will substantially lessen its security exposure, optimize operational resilience, improve compliance with cybersecurity standards, and advance the protection of confidential healthcare records by promptly addressing the discovered weaknesses and applying the suggested technical controls and organizational policies.

VULNERABILITY FINDINGS

The Six (6) vulnerabilities compromising the network system at Apex Healthcare Solutions and increasing the organization's exposure to critical cybersecurity threats, such as remote code execution, unauthorized access, system failure, possible disclosure of important clinical data and privilege escalation were detected on Kioptrix and Metasploitable 2 when executing a security assessment. Each of these vulnerabilities is explained below.

1. **Vulnerability Name:** Samba Trans2open Buffer Overflow. (Kioptrix)

Affected Service: Samba smbd (Port 139)

Brief Description: During testing, the Samba smbd service was found to mishandle unusually long input strings, creating a classic buffer overflow condition. Because this weakness sits in a service that typically runs with elevated privileges, a remote attacker who successfully triggers it could execute arbitrary code and, in the worst case, take full root-level control of the host.

Potential Attacker Goal: An attacker exploiting this flaw would primarily be looking to gain remote code execution and root access. From there, they could install malicious software, tamper with system files, create hidden privileged accounts, reach sensitive healthcare records stored on the system, and use the compromised machine as a springboard to attack other systems on the network.

2. **Vulnerability Name:** Apache mod_ssl Remote Buffer Overflow. (Kioptrix)

Affected Service: Apache HTTPS (Port 443)

Brief Description: The web server was running an outdated version of the mod_ssl module in combination with a vulnerable OpenSSL build. Specially crafted SSL requests sent to the server can trigger a buffer overflow, and in a successful attack this could let an intruder run arbitrary code with elevated privileges.

Potential Attacker Goal: A successful exploit would give an attacker a way to break into the web server, run malicious code, tamper with hosted applications, deface site content, interrupt healthcare-related services, and access confidential organizational data. It could also serve as an entry point for deeper attacks against the surrounding network.

3. **Vulnerability Name:** OpenSSH Authentication Overflow. (Kioptrix)

Affected Service: OpenSSH (Port 22)

Brief Description: Testing turned up an authentication weakness in the OpenSSH service running on the Kioptrix host. The issue lies in how the login process handles authentication attempts, which could be abused by a remote attacker. Because SSH is relied on for secure remote administration, a flaw like this in an unpatched system is a meaningful risk.

Potential Attacker Goal: By exploiting this weakness, an attacker could gain unauthorized remote access, escalate their privileges, run commands without authorization, and compromise systems that are critical to the organization. Once in, they could also work to keep that access over time and use it to reach other resources on the network.

4. **Vulnerability Name:** OpenSSH 4.7p1 Vulnerability (Metasploitable 2)

Affected Service: OpenSSH (Port 22)

Brief Description: The Metasploitable 2 host is running OpenSSH 4.7p1, a version that is no longer supported and carries well documented security issues. Since this software is past the end of life, attackers can rely on publicly available exploits rather than developing anything custom, which meaningfully widens the organization's attack surface.

Potential Attacker Goal: An attacker taking advantage of this would be after unauthorized server access with the ability to stick around, run malicious commands, move to other systems on the network, and reach confidential healthcare information. That foothold could also be used to launch further attacks against connected systems.

5. **Vulnerability Name:** Apache HTTP Server 2.2.8 (Metasploitable 2)

Affected Service: HTTP (Port 80)

Brief Description: The Metasploitable 2 server is running Apache HTTP Server 2.2.8, an old, unsupported release with a number of publicly known vulnerabilities. Keeping outdated web server software in production leaves the organization exposed to established exploits that put the confidentiality, integrity, and availability of hosted applications and services at risk.

Potential Attacker Goal: Exploiting the outdated Apache installation could let an attacker gain unauthorized access, compromise web applications, alter hosted content, disrupt

healthcare-related services, or reach confidential patient data. The compromised server could also be repurposed as a launch point for further attacks inside the organization's network.

6. Vulnerability Name: VSFTPD 2.3.4 Backdoor Vulnerability (CVE-2011-2523)
(Metasploitable 2)

Affected Service: FTP (Port 21)

Brief Description: The Metasploitable 2 system is running VSFTPD 2.3.4, a compromised release that shipped with a well known malicious backdoor tracked as CVE-2011-2523. This backdoor lets attackers gain unauthorized remote access using widely available exploit tools. Because this build is outdated and unsupported, it represents a critical risk to the organization.

Potential Attacker Goal: Exploiting this backdoor could allow an attacker to gain unauthorized remote access, establish a lasting foothold, run malicious commands, exfiltrate confidential healthcare data, move laterally across the network, and ultimately undermine the confidentiality, integrity, and availability of Apex Healthcare Solutions' critical systems and data.

RISK ASSESSMENT

Risk assessment was carried out to analyze the probability of exploitation, the probable damage on Apex Healthcare Solutions, and the entire level of security risk associated with each detected vulnerability. The analysis considered the potential outcomes of a successful cyberattack, the confidentiality of clinical data processed by the organization, the availability of public exploits, and the severity of the targeted services.

Based on the entire severity of each identified vulnerability, the risk levels were categorized as Medium or High.

	Vulnerability	Likelihood	Impact	Risk Rating
01	Samba Trans2open Buffer Overflow (Samba smbd, Port 139) (Kioptrix)	High	High	High
02	Apache mod_ssl Remote Buffer Overflow (Apache HTTPS, Port 443) (Kioptrix)	Medium	High	High
03	OpenSSH Authentication Overflow (OpenSSH Port 22) (Kioptrix)	Medium	High	High
04	OpenSSH 4.7p1 – Outdated SSH Service (Metasploitable 2)	High	High	High
05	Apache HTTP Server 2.2.8 (Metasploitable 2)	High	High	High
06	VSFTPD 2.3.4 Backdoor Vulnerability (CVE-2011-2523) (Metasploitable 2)	High	High	High

Explanation for Vulnerability 1:

Samba Trans2open Buffer Overflow vulnerability is publicly disclosed and can be exploited remotely against vulnerable Samba services. Successful exploitation allows malicious actors to obtain root-level privileges and execute arbitrary code. Due to the critical impacts of a complete

system breach and the availability of public exploits, this vulnerability is classified as a High likelihood, High impact, and an overall High Risk rating because with root-level access, an attacker can obtain sensitive medical records, move laterally across the organization's system, manipulate or erase critical operating system files, install persistent malware, and deactivate security controls.

Explanation for Vulnerability 2:

Apache mod_ssl Remote Buffer Overflow is a vulnerability that targets the critical web service responsible for secure communication. Though exploitation calls for certain factors and technical understanding, publicly available exploit information maximizes the possibility of attack. Due to its potentially severe impact on the confidentiality, integrity, and availability of Apex Healthcare Solutions' resources, this vulnerability is assigned a Medium likelihood, High impact, and a High risk rating because upon successful exploitation, threat actors could execute arbitrary code, endanger hosted applications, disclose important healthcare records, acquire unauthorized access to the web server and interrupt organizational services.

Explanation for Vulnerability 3:

OpenSSH Authentication Overflow vulnerability is a weakness that threatens the organization's remote administrative services. A successful exploitation attempt of this vulnerability could lead to exposure of critical systems and unapproved access remotely, even though exploitation of this vulnerability typically demands specific conditions and a weak OpenSSH configuration. Cyberattackers may maintain a persistent foothold, run malicious commands and expose sensitive organizational information. For this reason, though the likelihood of exploitation is rated as Medium, the security implications are dangerous, leading to a High impact and a High Risk rating.

Explanation for Vulnerability 4:

OpenSSH version 4.7p1 is an outdated and well-documented vulnerability that can be taken advantage of by threat actors using existing attack techniques. Persistent use increases the organization's level of exposure to full system compromise and unauthorized remote access. Because of the capability of causing severe damage and the ease of exploitation of this

vulnerability such as enabling threat actors to have unapproved access to confidential clinical records, expand access within the network, and establish persistence if successfully exploited, this is assessed as a High likelihood, High impact, and a High Risk rating.

Explanation for Vulnerability 5:

Apache HTTP server version 2.2.8 is a software that has publicly known security vulnerabilities and it's an outdated software application that is no longer supported by the Providers, thereby it is highly vulnerable to be exploited by threat actors. If successfully exploited, these attackers could obtain unauthorized access to web applications, cause web defacement, interrupt critical services and also extract confidential medical information. Considering the high exploitability and the extreme impact on the confidentiality, integrity, and availability of Apex Healthcare Solutions' information system, the vulnerability is issued a High likelihood, High impact, and generally a High risk rating.

Explanation for Vulnerability 6:

VSFTPD version 2.3.4 contains an amply documented malicious backdoor that permits attackers to acquire unauthorized remote access to unprotected systems using publicly available exploit techniques. If exploited successfully, attackers could move laterally across the network, retrieve sensitive clinical records, disrupt critical organizational services, and establish persistence. Given that this vulnerability is easy to exploit and poses serious consequences to the organization's confidentiality, integrity, and availability, it is categorized as having a High risk rating overall.

RECOMMENDED CONTROLS

These technical security controls are required to be done for all six vulnerabilities identified in order to decrease the chances of exploitation and bolster the Apex healthcare Solutions' cybersecurity status in general.

	Vulnerability	Recommended Control
01	Samba Trans2open Buffer Overflow (Samba smbd, Port 139) (Kioptrix)	Upgrade Samba to a supported, patched version; restrict SMB access using firewall rules.
02	Apache mod_ssl Remote Buffer Overflow (Apache HTTPS, Port 443) (Kioptrix)	Patch Apache/mod_ssl to a fixed version and disable weak/legacy SSL renegotiation handling.
03	OpenSSH Authentication Overflow (OpenSSH Port 22) (Kioptrix)	Patch/upgrade OpenSSH to a version without the authentication integer-overflow bug; rate-limit or restrict password-based authentication attempts.
04	OpenSSH 4.7p1 – Outdated SSH Service (Metasploitable 2)	Upgrade OpenSSH to the latest supported release; enforce key-based authentication over passwords.
05	Apache HTTP Server 2.2.8 – Outdated Web Server (Metasploitable 2)	Upgrade to a currently supported Apache version and apply a formal patch management schedule.
06	VSFTPD 2.3.4 Backdoor Vulnerability (CVE-2011-2523) (Metasploitable 2)	Remove the vulnerable VSFTPD version, replace it with a secure supported FTP service, and restrict FTP access to authorized users only, and monitor FTP activity continuously.

How Each Control Reduces Risk

Explanation for Vulnerability 1 (Samba Trans2open Buffer Overflow —Kioptrix):

In order to properly address the Trans2open Buffer Overflow vulnerability, the vulnerable Samba version should be upgraded immediately to a supported version. Also utilize all available vendor security patches to be part of a structured patch management process so as to eradicate known security-related flaws. The principle of least privilege, firewall rules, network segmentation should be put in place to limit SMB access. Furthermore, minimize the risk of root-level system compromise, remote code execution, and unauthorized access by enforcing system updates, regular security monitoring and continuous vulnerability scanning.

Explanation for Vulnerability 2 (Apache mod_ssl Remote Buffer Overflow —Kioptrix):

The bug is in how the SSL handshake size is validated before processing. Updating fixes that validation logic so malformed handshake data can no longer overflow the buffer, thereby removing the attacker's ability to execute code during the handshake.

Explanation for Vulnerability 3 (OpenSSH Authentication Overflow —Kioptrix):

Updating corrects the underlying size-calculation error directly, while rate-limiting reduces the number of crafted authentication attempts an attacker can send, making the overflow much harder to trigger even before a patch is fully applied.

Explanation for Vulnerability 4 (OpenSSH 4.7p1 – Outdated SSH Service —Metasploitable 2):

Upgrading removes the known, publicly documented vulnerabilities tied to this outdated OpenSSH version. Enforcing key-based authentication also reduces exposure to credential-guessing or interception attacks even if a future service flaw is discovered.

**Explanation for Vulnerability 5 (Apache HTTP Server 2.2.8 – Outdated Web Server
—Metasploitable 2):**

End-of-life software no longer receives security fixes, so every publicly known exploit against it remains open indefinitely. Upgrading closes those known holes, and a formal patch schedule prevents the same problem from recurring over time.

**Explanation for Vulnerability 6 (VSFTPD 2.3.4 Backdoor Vulnerability
—Metasploitable 2):**

FTP permissions should be constrained to authorized users through strong verification, MFA and RBAC where relevant and to ensure this happens, remediate the vulnerable VSFTPD version with a protected, enabled FTP solution or disable it if it's no longer essential. In addition to that, implement regular security monitoring, firewall restriction and vulnerability assessments so as to identify threats and decrease the risk of unauthorized remote access.

RECOMMENDED POLICIES

Several security gaps that were uncovered during the assessment can be tackled beyond technical controls but also through execution of comprehensive Governance, Risk, and Compliance (GRC) policies. These policies integrate security framework for controlling user access, identity verification, software patches, and consistent vulnerability remediation. Altogether, they aid in advancing regulatory compliance, minimizing cybersecurity risks, and strengthening Apex Healthcare Solutions' cybersecurity posture.

Policy	Purpose	Primary Vulnerabilities Mitigated
Access Control Policy	Restricts access to organizational systems and information based on business roles and the principle of least privilege	Samba trans2open Buffer Overflow, OpenSSH Authentication Overflow, OpenSSH 4.7p1, VSFTPD 2.3.4 Backdoor Vulnerability
Password Policy	Establishes requirements for strong passwords and secure user authentication.	OpenSSH Authentication Overflow, OpenSSH 4.7p1
Patch Management Policy	Ensures security patches and software updates are applied promptly to all systems	Samba trans2open Buffer Overflow, Apache mod_ssl Remote Buffer Overflow, OpenSSH Authentication Overflow, OpenSSH 4.7p1, Apache HTTP Server 2.2.8, VSFTPD 2.3.4 Backdoor Vulnerability
Vulnerability Management Policy	Establishes a continuous process for identifying, assessing, prioritizing, and remediating	Samba trans2open Buffer Overflow, Apache mod_ssl Remote Buffer Overflow, OpenSSH Authentication

	security vulnerabilities.	Overflow, OpenSSH 4.7p1, Apache HTTP Server 2.2.8, and VSFTPD 2.3.4 Backdoor Vulnerability.
--	---------------------------	---

ACCESS CONTROL POLICY

Purpose: The Access Control Policy lays out how access to organizational systems and information is granted, reviewed, and taken away. It's built around Role-Based Access Control (RBAC) and the principle of least privilege, so employees only have access to the systems and data they actually need to do their jobs. Keeping access this tightly scoped cuts down the risk of unauthorized access and limits how much damage a compromised account could do.

Why Apex Healthcare Solutions Needs It

Apex Healthcare Solutions handles confidential patient information along with other sensitive organizational data, which makes it a healthcare organization with a lot to protect. Limiting who can reach these resources helps guard critical systems against unauthorized users, insider threats, and attackers who gain unauthorized access through compromised accounts or exposed network services.

Vulnerabilities Mitigated

- Samba trans2open Buffer Overflow (Kioptrix)
- OpenSSH Authentication Overflow (Kioptrix)
- OpenSSH 4.7p1 Vulnerability (Metasploitable 2)
- VSFTPD 2.3.4 Backdoor Vulnerability (Metasploitable 2)

By putting RBAC, least privilege, regular access reviews, and solid account management procedures into practice, this policy lowers the odds of unauthorized system access and limits the fallout if an attack does succeed.

PASSWORD POLICY

Purpose: The Password Policy sets the baseline requirements for creating, managing, and protecting passwords. It calls for strong, unique passwords, requires default credentials to be changed, and pushes users toward secure authentication habits. It also encourages Multi-Factor Authentication (MFA) as an added layer of account protection.

Why Apex Healthcare Solutions Needs It

Weak authentication is still one of the most common ways attackers get in. A solid Password Policy makes it harder for accounts to be compromised and helps keep critical healthcare systems safe from unauthorized login attempts.

Vulnerabilities Mitigated

- OpenSSH Authentication Overflow (Kioptrix)
- OpenSSH 4.7p1 Vulnerability (Metasploitable 2)

With strong password requirements, MFA, regular password rotation, and secure credential handling in place, this policy strengthens how users authenticate and reduces the risk of unauthorized access.

PATCH MANAGEMENT POLICY

Purpose: The Patch Management Policy defines how security patches and software updates are identified, tested, approved, and rolled out across the organization's systems. Its goal is to make sure vulnerabilities get addressed quickly, before an attacker has the chance to exploit them.

Why Apex Healthcare Solutions Needs It

A good number of the vulnerabilities found during the security assessment came down to outdated or unsupported software. A formal Patch Management Policy helps keep operating systems, applications, and network services current, which cuts down exposure to known vulnerabilities and strengthens overall system security.

Vulnerabilities Mitigated

- Samba Trans2open Buffer Overflow (Kioptrix)
- Apache mod_ssl Remote Buffer Overflow (Kioptrix)
- OpenSSH Authentication Overflow (Kioptrix)
- OpenSSH 4.7p1 Vulnerability (Metasploitable 2)
- Apache HTTP Server 2.2.8 (Metasploitable 2)
- VSFTPD 2.3.4 Backdoor Vulnerability (Metasploitable 2)

By keeping software updates and security patches on a regular schedule, this policy meaningfully reduces the organization's exposure to known vulnerabilities.

VULNERABILITY MANAGEMENT POLICY

Purpose: The Vulnerability Management Policy sets up an ongoing process for identifying, assessing, prioritizing, fixing, and monitoring security vulnerabilities across the organization. It calls for regular vulnerability assessments, risk evaluations, remediation tracking, and follow-up verification to build stronger resilience against cyber threats over time.

Why Apex Healthcare Solutions Needs It

Cyber threats are constantly changing, which is exactly why ongoing vulnerability management matters for protecting healthcare systems and patient information. A formal policy lets Apex Healthcare Solutions catch weaknesses before attackers can take advantage of them, and it makes sure remediation work is prioritized based on actual business risk.

Vulnerabilities Mitigated

- Samba Trans2open Buffer Overflow (Kioptrix)
- Apache mod_ssl Remote Buffer Overflow (Kioptrix)
- OpenSSH Authentication Overflow (Kioptrix)
- OpenSSH 4.7p1 Vulnerability (Metasploitable 2)
- Apache HTTP Server 2.2.8 (Metasploitable 2)
- VSFTPD 2.3.4 Backdoor Vulnerability (Metasploitable 2)

This policy supports the continuous identification, assessment, prioritization, remediation, and monitoring of all identified vulnerabilities, helping Apex Healthcare Solutions reduce future cybersecurity risks and strengthen its overall security posture.

CONCLUSION

The security assessment performed on the Kioptrix and Metasploitable 2 systems successfully detected six (6) major security vulnerabilities affecting critical services within Apex Healthcare Solutions' network environment. These vulnerabilities are Samba Trans2open Buffer Overflow, Apache mod_ssl Remote Buffer Overflow, OpenSSH Authentication Overflow, OpenSSH 4.7p1, Apache HTTP Server 2.2.8, and the VSFTPD 2.3.4 Backdoor Vulnerability (CVE-2011-2523). Altogether, these identified issues indicate that multiple systems are operating unsupported or vulnerable software versions that expose the organization to root-level privileges, service disruption, unauthorized access, and potential compromise of confidential healthcare information.

The risk assessment showed that all uncovered vulnerabilities pose a severe threat to the organization, with most of them being evaluated as High Risk due to their possible damage on the confidentiality, integrity and availability (CIA) of Apex Healthcare Solutions' information assets. The assessment also revealed that the organization's exposure to cyber risks is increased by poor security configurations, inadequate vulnerability management processes and persistent use of outdated software.

To resolve these security gaps, the report suggests applying proper technical security controls, including Multi-Factor Authentication (MFA), network segmentation, continuous security monitoring, strong authentication mechanisms, regular vulnerability assessment and timely software patching. Furthermore, the application of core Governance, Risk, and Compliance (GRC) policies, such as Access Control Policy, Patch Management Policy, Vulnerability Management Policy, and Password Policy will offer a structured framework for sustaining long-term cybersecurity resilience and minimizing future security risks.